fintrust.

FinTrust Project Master

Transaction Monitoring & Risk Alert Platform

RELEASE 1 | 13 October 2026

Source checkpoint risk-v2 / a474566

Authoritative consolidated documentation. Explicitly separates local verification, historical deployment evidence and pending live gates.

Fictional client: Imbokodo Bank. No real bank adoption or production compliance certification is claimed.

Contents

1. Executive Summary 4

2. Imbokodo Bank Case Study 5

3. Problem Statement 5

4. Product North Star 5

5. Project Scope 5

6. Assumptions and Constraints 6

7. Stakeholders 6

8. Users and Role Separation 6

9. Functional Requirements 7

10. Non-functional Requirements 7

11. Planning and Development Approach 7

12. End-to-End Business Flow 7

13. Transaction Lifecycle 10

14. Risk Monitoring Model 10

15. Risk Scenarios and Rules 11

16. Quarantine and Recovery 11

17. Risk Events 12

18. Alerts 13

19. Analyst Review Workflow 13

20. Accounts and Transaction History 14

21. Insights and Reporting 14

22. Audit and Traceability 14

23. Technical Failure / Retry / DLQ 15

24. AWS Architecture 15

25. Architecture Decisions and Trade-offs 17

26. S3 Storage Model 17

27. PostgreSQL Design 17

28. DynamoDB Role 19

29. Security / IAM / RBAC 19

30. POPIA / Data Governance 19

31. Retention Strategy 20

32. Cost Governance 20

33. AWS Budgets 20

34. Testing Strategy 21

35. CI/CD 22

36. Release Verification 23

37. Challenges and Failures 23

38. Lessons Learned 23

39. Current Deployment State 24

40. Future Roadmap 24

41. AI Investigation Assistant 24

42. Local Workflow Completion and Remaining Cloud Gates 24

43. Risk V2 Presentation Evidence 27

44. If I Had More Time and Budget 27

45. References 28

1. Executive Summary

LOCAL VERIFIED

FinTrust is a transaction monitoring and risk investigation platform. It accepts CSV files, preserves transaction identity and source evidence, scores risk and records each review decision. It does not move funds, reverse charges or establish fraud.

Risk Model V2 and explainable UX VERIFIED: 903 PASSED | 0 FAILED | 1 EXPECTED SKIP (904 collected, +56 checks versus baseline). Final focused model/CSV/browser pass: 75; eight previously affected checks passed after explicit V2 oracle updates. Seven in-suite browser gates plus the separate four-role CSV/report gate passed. Preserved financial/audit data and credentials are unchanged. No historical rescoring, AWS contact, push or Linux run.

Risk model V2 uses one mutually exclusive amount component plus independent velocity, cross-border and possible-duplicate components. It remains deterministic, explainable and non-ML; its score prioritises investigation and is not a fraud or compliance verdict.

Amount <=50,000: 0; >50,000 to <=100,000: 15; >100,000 to <=200,000: 25; >200,000: 40. Velocity adds 25, cross-border adds 15 and possible duplicate adds 20. Maximum 100. LOW: 0-19; MEDIUM: 20-39; HIGH: 40-100. Thresholds use the original transaction currency; no FX conversion.

New assessments use fintrust-r2-rules-2026-10-13. V1 used overlapping HIGH_AMOUNT/VERY_HIGH_AMOUNT weights and additional transfer/merchant-marker signals. Existing V1 scores, classifications, source and rule version remain frozen; V2 does not rescore them. The current Release 1 validation, identity and review lifecycle remains in place.

Review eligibility migration 006 replaces the old hard-coded threshold with a version-aware guard. V1 LOW 30 remains ineligible; V2 MEDIUM 25 can open a review. The migration changes one existing trigger function, with no new tables or columns. Migrations 001-005 and historical rows remain unchanged. Live application remains a separate approved gate.

Controlled local presentation example: 150,000 ZAR; 8 accepted transactions in the closed 09:55-10:00 UTC window; country US versus ZA. Amount +25, velocity +25, cross-border +15, duplicate +0 = 65% - HIGH. Transaction -> Measured values -> Components -> Score -> Risk level -> Analyst investigation. This is not a probability of fraud; there is no invented partial velocity weight.

Baseline a474566 verified 847 passed / 0 failed / 1 expected skip, seven isolated browser gates and the preserved analyst01 workspace. That baseline is historical proof, not final proof of the changed V2 semantics. New focused, scenario, full-regression and browser evidence is recorded under docs/EVIDENCE/12-e2e/risk-model-v2/.

AWS untouched; nothing pushed; exact-source Linux verification and live AWS E2E remain pending. Behavioural dimensions and production-scale capacity remain planned.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md; docs/EVIDENCE/12-e2e/console-overhaul/final-local-freeze.json

2. Imbokodo Bank Case Study

PLANNED

Imbokodo Bank is a fictional client created for this project case study. Its operations team needs to reconcile transaction exports and investigate exceptions without losing the source evidence or confusing invalid data with financial risk.

The case study provides business context, not a claim of a real bank engagement, production adoption or regulatory approval.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

3. Problem Statement

LOCAL VERIFIED

Manual file inspection can overlook invalid rows, repeated source transactions and unexplained risk decisions. Retrying partial processing can duplicate financial records or notifications unless identity and recovery are deliberate.

FinTrust separates data-quality decisions, ledger acceptance, risk assessment, investigation and technical recovery. Every submitted row needs a recorded outcome; technical failure must not silently erase accepted financial activity.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

4. Product North Star

LOCAL VERIFIED

What happened? Why is it risky? What should I do next?

FinTrust helps a Risk Analyst answer these questions quickly, consistently and with evidence. Start with the Analyst workbench, investigate risk events and complete assigned reviews. Use Insights and Reports for supporting analysis.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; frontend/release1.html

5. Project Scope

LOCAL VERIFIED

Release 1 covers CSV admission, exact duplicate protection, positive-amount transaction validation, quarantine correction, deterministic scoring, durable review and scoped read/report/audit workflows.

Refund/reversal accounting, foreign-exchange conversion, live account balances, enterprise federation, durable notification inboxes and AI investigation are outside the implemented first release. Local direct processing does not establish cloud transport completion.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/RELEASE1_OPERATIONS.md

6. Assumptions and Constraints

LOCAL VERIFIED

Use synthetic data for practice. Region remains af-south-1. The database is private; no NAT Gateway or public RDS access is part of the approved architecture. Lambda targets Python 3.12 / Linux x86_64.

Amount thresholds operate per transaction currency, with no implied FX normalization. Late arrivals do not retroactively rescore previous transactions. Historical package verification is tied to its exact source and checksum.

Source: docs/RELEASE1_OPERATIONS.md; backend/fintrust/rules.py

7. Stakeholders

PLANNED

The fictional bank operations sponsor owns business scope and approves risk policy. Analysts investigate transactions; Auditors examine evidence; Administrators govern access; Maintainers handle technical recovery.

A data owner must approve retention and disposal. A deployment owner controls account mutations and cost acceptance. These accountability assignments are the intended operating model, not evidence that real organizational appointments exist.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/SECURITY.md

8. Users and Role Separation

LOCAL VERIFIED

Named local users have a stable user ID and immutable username/subject, display name, optional email, role, ACTIVE/DISABLED status, creation time and actual last sign-in time. Legacy user IDs derive deterministically from the existing subject. Unknown historical creation times remain unknown.

Admin creates named records and changes role/status with a mandatory reason and governance audit. Creation does not issue a credential. Private local enrollment uses a hidden prompt, stores only a SHA256 hash, cannot create an identity or change its role/account scope, and cannot silently replace an existing credential. The registry is operator-controlled and ignored by Git; production federation/password authentication remains a separate gate.

Backend checks deny unsupported actions on each request. Analyst investigates, corrects assigned-account quarantine and claims/completes owned reviews. Admin governs users and review assignment, never clears/confirms risk or edits financial evidence. Auditor is read-only with audit access; Maintainer handles technical recovery only. Disable blocks subsequent authentication but preserves identity, ownership and audit. Admin must explicitly reassign unresolved work; no automatic role inheritance.

Manage users in a compact table: name, username, role, status, last sign-in and credential readiness. Search filters only the already-authorized registry list; sorting never widens authority. No Datadog assets or proprietary branding are used.

Role	Responsibility
Analyst	Upload, correct quarantine, investigate and decide reviews within scope
Auditor	Read-only scoped evidence, reports and audit
Administrator	User/account governance, oversight and unknown-account cases
Maintainer	Technical diagnosis/recovery; no financial review decisions

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/auth.py

9. Functional Requirements

LOCAL VERIFIED

Record source system/reference, canonical transaction identity, fingerprint, file/batch and row provenance. Reject invalid files; quarantine invalid rows; retain all accepted risk levels.

Expose transaction/risk/review/delivery states, correction lineage and actor-attributed history. Reconcile accepted, quarantined, duplicate, pending and failed outcomes. Prevent blind duplicate notification retries.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md

10. Non-functional Requirements

PENDING VERIFICATION

Private networking, verified TLS, least privilege and account-scoped access are required. Atomic financial commits, immutable evidence, bounded reads and deterministic scoring protect correctness.

Throughput, availability SLA, load capacity and production incident response are not established by functional test counts. Production performance has not been verified.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/SECURITY.md

11. Planning and Development Approach

LOCAL VERIFIED

I verify each phase locally before requesting approval for live AWS changes. Domain rules and artifacts are frozen before deployment; read-only preflight checks assumptions before writes.

The completed local sequence covers repository structure, flow audit, lifecycle, quarantine recovery, review ownership, investigation, Analyst workbench and 20-scenario verification. Existing AWS budget configuration is verified and preserved. Next: exact-source Linux packaging and controlled cloud integration.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/REPOSITORY_STRUCTURE.md

12. End-to-End Business Flow

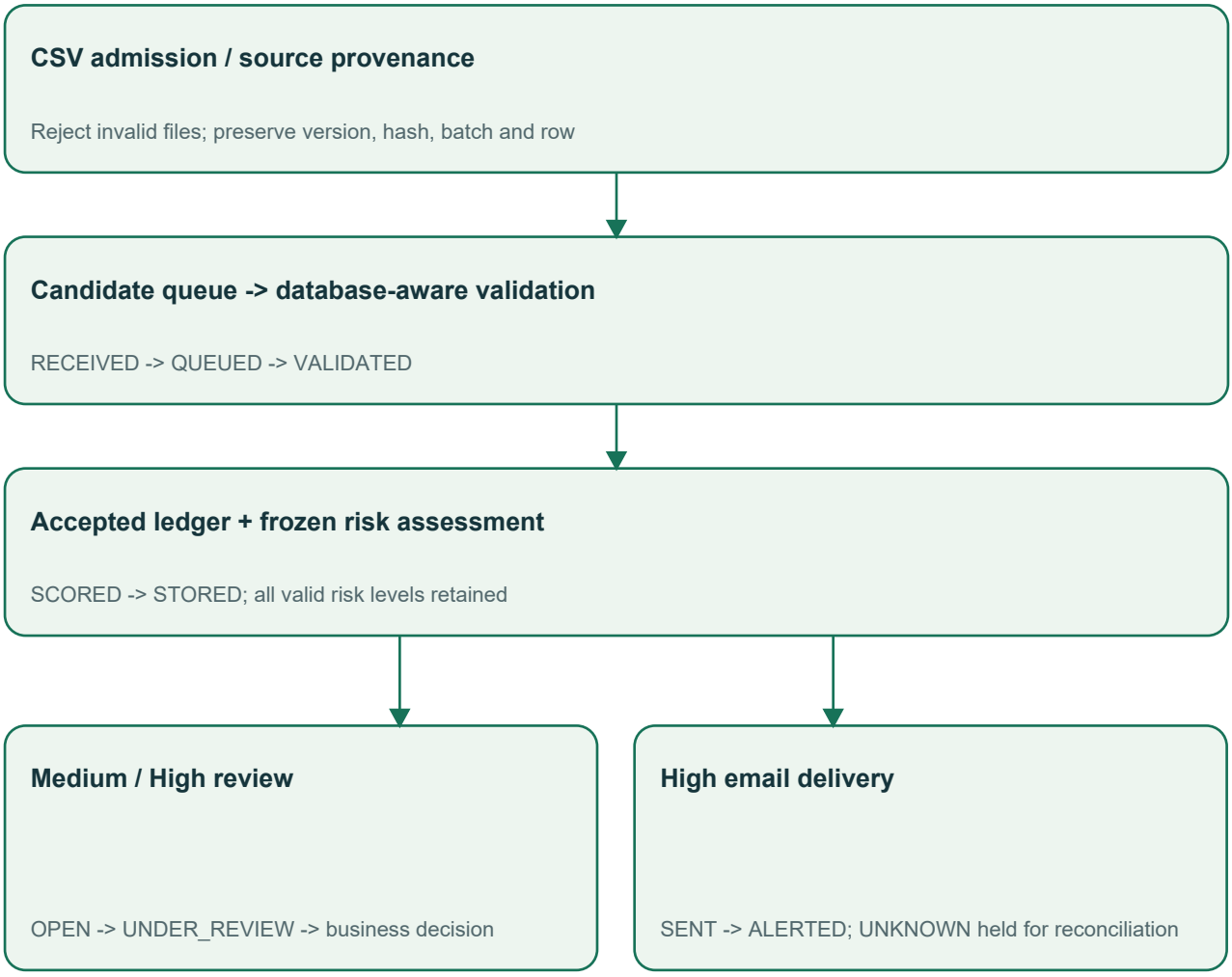
LOCAL VERIFIED

Cloud target: Analyst CSV upload -> input S3 -> ingest parsing/admission -> SQS FIFO candidates -> private consumer database-aware validation -> quarantine OR accepted ledger and frozen scoring -> DynamoDB projection. Medium/High review work is committed independently of High-only email delivery.

The local demonstration uses mocked S3 and a direct SQL consumer helper. It does not prove live FIFO, Streams or SES. Keep the original process diagrams as historical references. Use the processing order above and lifecycle contract for the current implementation.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

Processing, review and delivery



Invalid rows branch to quarantine. Corrections create new linked occurrences and repeat validation/deduplication. Review does not wait for email.

Supporting detailed diagram: docs/presentation/diagrams/FinTrust_Activity_Diagram.pdf

13. Transaction Lifecycle

LOCAL VERIFIED

Actual processing order: RECEIVED -> QUEUED -> VALIDATED -> SCORED -> STORED. Ingest is outside the VPC; account-aware validation happens in the private consumer after candidate handoff.

Migration 003 adds transaction_lifecycle_events as append-only observations, not a competing mutable status model. Meaningful events record sequence, time and system actor. Human correction/review events retain their authenticated actor. Old rows are not backfilled with invented history.

Risk, review, delivery and processing are separate dimensions. Reads expose provenance and a bounded timeline; timeline_complete=false discloses missing or truncated history. The runtime must not be deployed before migration 003 and its service grants are approved.

Branch	Authority / meaning
Quarantine	Original occurrence terminal; correction creates linked new occurrence
Review	OPEN -> UNDER_REVIEW -> CLEARED / CONFIRMED_RISK / ESCALATED
Recovery	TECHNICAL_FAILURE -> RETRY -> RECOVERED; DLQ needs observed evidence
Projection failure	Financial state remains STORED; pending external projection is recoverable

Source: docs/architecture/TRANSACTION_LIFECYCLE.md; sql/migrations/003_transaction_lifecycle.sql

14. Risk Monitoring Model

LOCAL VERIFIED

Risk model V2 uses one mutually exclusive amount component plus independent velocity, cross-border and possible-duplicate components. It remains deterministic, explainable and non-ML; its score prioritises investigation and is not a fraud or compliance verdict.

Amount <=50,000: 0; >50,000 to <=100,000: 15; >100,000 to <=200,000: 25; >200,000: 40. Velocity adds 25, cross-border adds 15 and possible duplicate adds 20. Maximum 100. LOW: 0-19; MEDIUM: 20-39; HIGH: 40-100. Thresholds use the original transaction currency; no FX conversion.

New assessments use fintrust-r2-rules-2026-10-13. V1 used overlapping HIGH_AMOUNT/VERY_HIGH_AMOUNT weights and additional transfer/merchant-marker signals. Existing V1 scores, classifications, source and rule version remain frozen; V2 does not rescore them. The current Release 1 validation, identity and review lifecycle remains in place.

Every new result contains four components, including zero/non-triggered components, with observed value, amount band or threshold, points, explanation, evaluation timestamp and rule version. Velocity includes the configured closed window, actual earliest/latest accepted times and current account/count. Duplicate evidence includes matching references/fields and recorded seconds of proximity; these measurements are never reconstructed from later history.

Review eligibility migration 006 replaces the old hard-coded threshold with a version-aware guard. V1 LOW 30 remains ineligible; V2 MEDIUM 25 can open a review. The migration changes one existing trigger function, with no new tables or columns. Migrations 001-005 and historical rows remain unchanged. Live application remains a separate approved gate.

User-facing scores show a percentage, including 0%; missing assessment stays Not assessed. Rule-based risk score. This percentage represents the configured risk score, not the probability of fraud. Numeric API/storage semantics stay 0-100. Historical amount bands are grouped for display and scenario counts, with original identifiers available in technical evidence.

Zero risk score is distinct from a zero-amount row: zero amounts remain invalid at admission. Legacy decision compatibility hints are not financial authorization; accepted ledger records and human review outcomes remain authoritative.

Source: backend/fintrust/rules.py; docs/architecture/FINTRUST_FLOW_AUDIT.md

15. Risk Scenarios and Rules

LOCAL VERIFIED

Velocity remains more than 5 accepted transactions in the closed 300-second event-time window, current included. Five versus six and the exact boundary remain tested. An hourly or behavioural velocity rule is not implemented.

Amount contributes once. Independent components accumulate toward 100. All accepted LOW/MEDIUM/HIGH transactions remain in the ledger; MEDIUM/HIGH open review, and HIGH enters the independent alert path.

Component	Points / boundary
Amount risk	0 / 15 / 25 / 40; one strongest applicable band
High velocity	25; more than 5 accepted transactions in the closed preceding 300 seconds, current included
Cross-border	15; country differs from ZA or explicit cross-border flag
Possible duplicate	20; distinct source references, matching account/merchant/amount/currency/source system and debit type within inclusive +/-120 seconds

Source: backend/fintrust/rules.py; docs/RELEASE1_E2E_MANIFEST.md

16. Quarantine and Recovery

LOCAL VERIFIED

Original restricted safe evidence, reason code/detail, source version, batch and row remain immutable. Corrections are independently versioned, attributed to the named Analyst and linked to a new occurrence. The existing validator, identity checks and normal processing run again; correction never approves a ledger write directly.

Backend recovery detail exposes OPEN, CORRECTED, REVALIDATION_FAILED, ACCEPTED or REJECTED derived from existing workflow and durable outcome records. No competing status table was added. Failed attempts retain latest reason and every prior correction. Accepted and duplicate resolutions link to the canonical transaction; duplicates do not add a ledger entry.

Review original and corrected values, the correcting Analyst, correction time, attempt count, outcome and audit timeline. Evidence reads are version-pinned, bounded and account-scoped; incomplete history is explicitly marked. Unknown/missing-account rows are Admin-visible for oversight. By explicit approval, the original authenticated local uploader can correct their own row to an existing assigned account. Re-uploading an identical file does not transfer ownership; historical unowned cases and known

unassigned accounts remain blocked. Admin cannot perform financial corrections.

Local correction/projection outbox retry remains durable in PostgreSQL. Mock S3 evidence is session-limited, as before; this is not a live retention proof. No credential or sensitive raw payload is logged.

Quarantine now opens a list-preserving recovery drawer with original and corrected values, issue, attempts/outcome, immutable correction history and recorded timeline. Existing account-scoped correction/revalidation actions are reused. Unknown rows follow the approved original-upload ownership exception; missing original evidence still fails closed.

The compact quarantine list shows reference, reason, recovery/workflow status, account, recorded age and source provenance. Age derives from quarantined_at. The correcting Analyst is available in detail, not in the current list API. Correct / Revalidate opens the existing correction form; submission still requires normal validation, duplicate checks and processing.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/release_workflow.py; backend/fintrust/workflow_api.py

17. Risk Events

LOCAL VERIFIED

risk_events accompanies every accepted scored transaction, including Low. A risk event is evidence of assessment; it is not synonymous with a High alert or confirmed fraud.

A transaction links its frozen score and rule explanations, risk event, review state, delivery state and source occurrences. Similar charges with distinct identity remain separate ledger records for investigation.

GET /v1/risk-events/{event} assembles account-scoped transaction/source, frozen signals, owner/review, independent alert state, related history and actual audit timeline. Event data stays authoritative in PostgreSQL; delivery claims stay independent in DynamoDB. No competing risk-event state table is introduced.

Investigation drawer retains the queue and follows WHAT HAPPENED / WHEN / WHERE / WHY IS IT RISKY / NEXT STEPS. The displayed last update is the latest review-history change. Compact severity/scenario/assignee/account/status controls, server-side sorting and filtered total/HIGH/active counts operate before pagination. Related history is limited to 20 rows and explicitly reports truncation.

Account baseline is current-ledger, same-currency accepted transactions in the preceding 30 event-time days, strictly before the investigated transaction. It is labelled as contextual data, not the original scoring snapshot; there is no FX aggregation or fabricated comparison. Prior risk/review counts and related transactions come from scoped SQL.

The Analyst Overview has six scoped metrics and an active-review table sorted by score. Investigate opens the existing evidence drawer. Transaction activity, risk distribution, scenario counts and review outcomes reuse current read-only APIs. Scenario matches can overlap. High-risk alerts count flags, not email delivery. Historical unscored rows are excluded from the processed metric but remain visible in transaction activity.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; sql/schema.sql

18. Alerts

LOCAL VERIFIED

High risk enters the email path. Conditional DynamoDB claims coordinate delivery and durable SQL receipts support visibility. SENT evidence permits ALERTED; PENDING, SENDING or UNKNOWN must not be displayed as sent.

A provider timeout may mean the email was sent without a recorded response. UNKNOWN is held for reconciliation, not blindly resent. Exactly-once email is not guaranteed. Medium/High review work remains visible even if delivery fails.

Investigation displays the existing logical HIGH intent and independent PENDING / SENT / FAILED / RETRYING delivery evidence. SENDING and UNKNOWN remain conservative reconciliation states. Missing delivery evidence is not proof of sending; delivery failure does not rollback the ledger or review. SQL legacy receipts and DynamoDB delivery claims remain explicitly distinguished.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/alert_delivery.py

19. Analyst Review Workflow

LOCAL VERIFIED

Each Medium/High review is initially unassigned, with at most one named Analyst owner. Analysts may self-claim an OPEN review; a second claim or stale version is rejected. Only the current owner can make a business decision. Admin may assign, reassign or release an active review with a mandatory reason, never make its decision.

Migration 004 extends the existing transition guard for reassignment/release and adds a reviewer/status/created-time queue index. It reuses reviewer_subject, version and immutable risk_review_history. Escalated reassignment preserves the previous decision, actor, time and resolution; escalation cannot be unassigned. The new owner may resume investigation through the existing transition workflow.

PostgreSQL SELECT FOR UPDATE serializes competing mutations; expected_version rejects stale requests and request IDs support safe replay. A single-host cross-process registry lock and fresh active-role checks prevent a concurrent disable/role change from slipping into a new assignment or human mutation.

My Reviews, Unassigned, All Open, High Risk and Over SLA filters run on the scoped backend before pagination. Age is calculated from creation time. FINTRUST_REVIEW_SLA_SECONDS is optional (60 through 31536000); absent configuration yields an explicit unconfigured result, not an invented business deadline.

POST /v1/reviews/{event}/notes appends an investigation note only for the currently assigned active Analyst in UNDER_REVIEW. Expected version, row lock, request digest and replay protection reuse risk_review_history. The current note projection can change, but each prior note remains immutable in history.

Local additive migration 005_investigation_notes.sql evolves only the existing transition guard to allow a same-owner UNDER_REVIEW note append. It adds no table/column/state. Base -> 001 -> 002 -> 003 -> 004 -> 005 is tested locally; frozen 001-004 files remain unchanged. Current live runner approval does not implicitly include 003-005.

Clear / Confirm Risk / Escalate require notes, actor and resolution evidence. Wrong Analyst, Admin, Auditor and Maintainer cannot decide or append notes. Administration can assign but cannot substitute for Analyst judgment. Existing terminal/escalated recovery and ownership rules remain authoritative.

Reviews over SLA reuse the configured backend deadline. With no configured deadline, the metric shows Not configured. The Risk Events Over SLA filter uses the existing active-review endpoint; it does not create a new rule or include closed reviews. Other filters remain scoped and run before pagination.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/workflow_api.py

20. Accounts and Transaction History

LOCAL VERIFIED

Transactions and account history use scoped authorized reads, time and currency context, and stable transaction identity. Stored historical rows without assessment remain Not assessed rather than receiving invented scores.

Customer/account foreign keys protect reference integrity. Unknown accounts are quarantined, not silently created. The balance column is not a real-time banking balance engine; transaction totals are not available funds.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; sql/schema.sql

21. Insights and Reporting

LOCAL VERIFIED

Insights expose scoped SQL aggregates and exact tabular equivalents. Transaction/currency context must remain visible; cross-border activity alone is not suspicious.

Reports filters now query accepted ledger activity by UTC date period and currency; exports retain the current authorized query page. Backend scheduled monthly JSON/CSV outputs to S3 exist but are not a complete generated-report catalogue in the UI. A monthly summary is not a full ledger archive.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; backend/fintrust/report.py

22. Audit and Traceability

LOCAL VERIFIED

Trace from source system/reference and fingerprint through file SHA256, batch, row, canonical tx_id, frozen assessment and human decision. Ingestion outcomes and reconciliation disclose duplicates and pending failures.

Append-only lifecycle and review histories prevent silent overwrites. Local governance records are not CloudTrail or enterprise identity proof. Evidence is sanitized: no tokens, credentials or secret values belong in logs or screenshots.

User governance preserves named actor, reason and before/after metadata in existing versioned receipts. Review history exposes claim, reassignment, release and decision actions. Correction history records human submission and authoritative system revalidation/ledger outcomes. Disable and display-name changes do not rewrite past actors or delete audit.

Source: docs/architecture/TRANSACTION_LIFECYCLE.md; docs/SECURITY.md

23. Technical Failure / Retry / DLQ

LOCAL VERIFIED

A failed projection after financial commit leaves the SQL ledger STORED. Replay uses immutable identity and the frozen result, then marks RECOVERED only after durable completion. RETRY_REQUESTED by an operator is different from an executed worker retry.

FIFO batch processing stops at the first failure and reports failed plus unprocessed IDs. The transaction DLQ and async failure queues hold technical failures; they are not quarantine. Automatic lifecycle DLQ transport/reconciliation remains deferred.

A SQL outage before occurrence registration cannot create a SQL audit event. Worker transport evidence remains authority; the API never fabricates missing observations.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md; docs/OPERATIONS.md

24. AWS Architecture

PENDING VERIFICATION

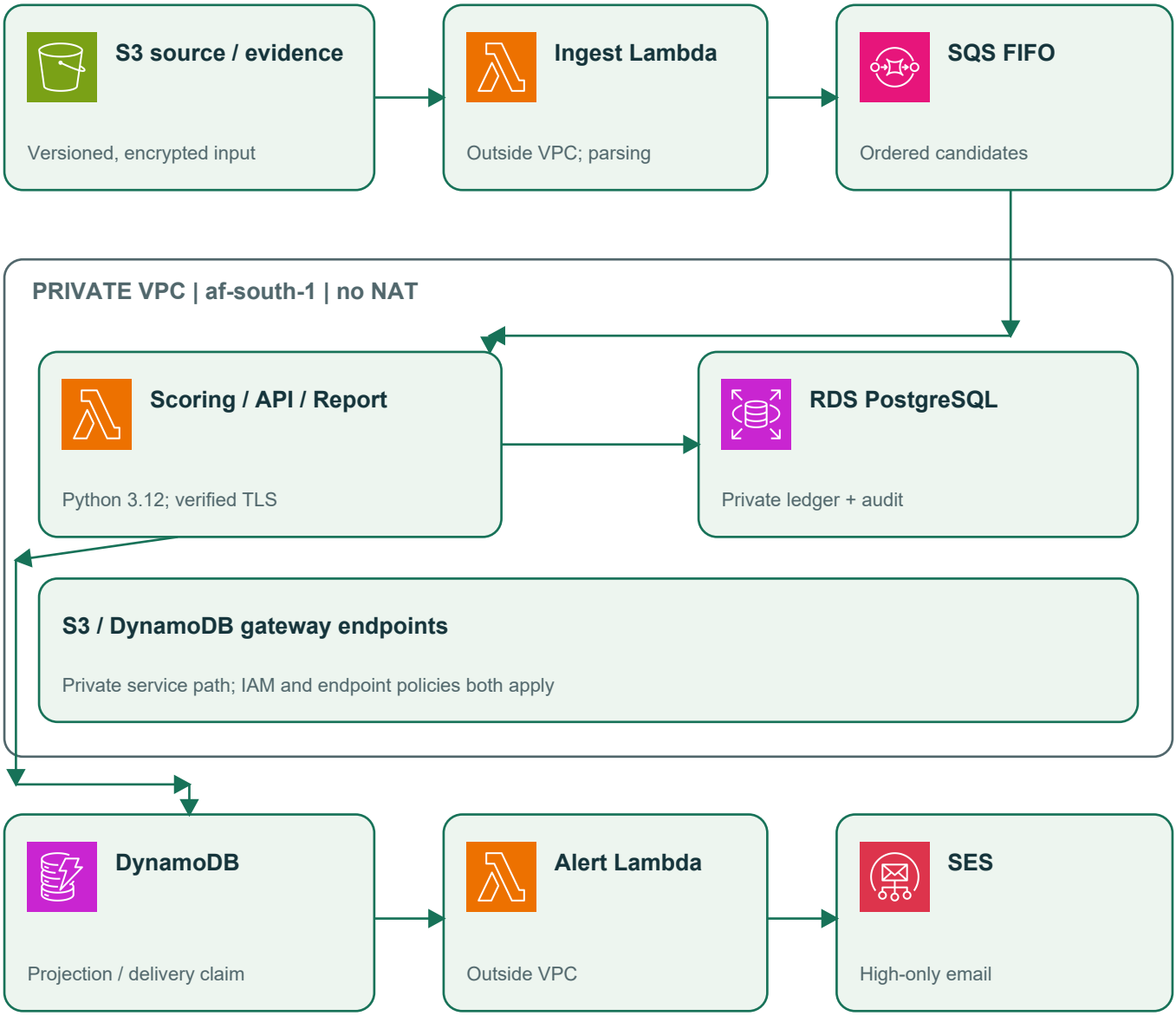
af-south-1 is preserved. Private application subnets reach the database security group on TCP 5432 only from the approved application security group. S3 and DynamoDB gateway endpoints support the private workers without NAT.

Ingest and alert run outside the VPC because their selected cloud handlers do not require SQL. Scoring, API and report are private SQL clients. SES and trigger wiring need separate live verification.

Official AWS icons in the retained diagrams identify services; they do not prove that current-release wiring is deployed. Diagram colors reflect their historical presentation checkpoint. Temporary Secrets Manager migration networking was deleted after read-only preflight.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/diagrams/README.md

Architecture - official AWS icons



Official AWS icons retained in docs/diagrams/aws-icons/. Foundation historically verified; current-release wiring pending. Temporary migration interface endpoint is not standing infrastructure.

Supporting detailed diagram: docs/presentation/diagrams/FinTrust_AWS_Architecture.pdf

25. Architecture Decisions and Trade-offs

LOCAL VERIFIED

I used SQS FIFO for per-account ordering and SQL uniqueness to prevent replay beyond the FIFO deduplication window. PostgreSQL stores the authoritative ledger; DynamoDB holds immutable projections and delivery claims.

I kept NAT out of the design to avoid standing cost and limit outbound access. Private bootstrap credentials need a reviewed Secrets Manager network path. A temporary interface endpoint supported the historical read-only preflight and was cleaned up afterward.

I chose Single-AZ RDS, disabled consumers and small capacity to control development cost. Adoption, scale and HA need independent production review.

The original FinTrust brief defines the scope. External references validate implementation decisions. No AML expansion, funds authorization, account freezing or autonomous fraud/regulatory decisions were added. Industry suggestions outside the brief remain future scope.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; infrastructure/PRIVATE_RDS_MIGRATION_PLAN.md

26. S3 Storage Model

LOCAL VERIFIED

Raw input, quarantine and report buckets separate operational data classes. Stage 2 uses private, versioned buckets with SSE-KMS, secure-transport policy and a shared regional customer-managed key. Object version/checksum pinning ties package evidence to the exact uploaded artifact.

Quarantine safe payloads remain sensitive. Retained bucket/key resources and noncurrent versions can continue costing money after stack deletion. Current reports do not replace archival exports.

Source: infrastructure/storage.py; docs/OPERATIONS.md

27. PostgreSQL Design

LOCAL VERIFIED

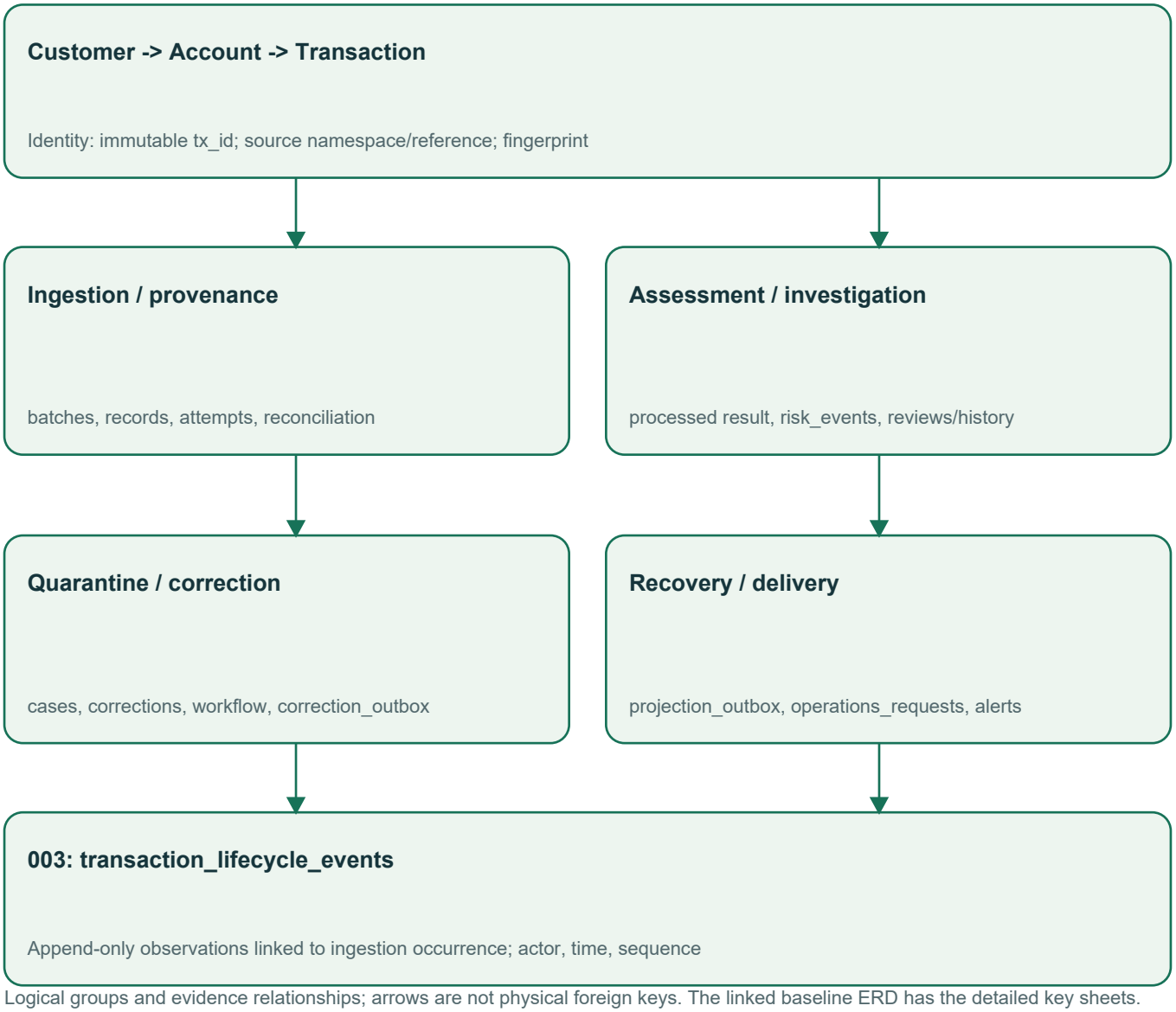
Authoritative base: the checksum-bound section of sql/schema.sql before Additive identity hardening, rendered by tools/render_release1_base.py with sql/bootstrap/release1-base-manifest.json. Six base tables include Phase 1 alert upgrades. Apply verified identity 001, workflows 002 and lifecycle 003 in order. Catalog prerequisites reject drift. Synthetic seeds are not required for live bootstrap.

Core domains: customers/accounts; transactions and frozen processed_transactions; ingestion batches/records/attempts/reconciliation; quarantine/corrections/outbox; risk events/reviews/history; alerts; projection and operations recovery.

The 17-table baseline ERD predates 003, which adds transaction_lifecycle_events. Migration 004 changes only review guard/index; no new tables. Its checksums preserve earlier history and validate the current catalog. Latest live preflight found no base schema. Live bootstrap, 001/002/003/004/005 and grants remain unapproved.

Source: sql/schema.sql; sql/migrations/003_transaction_lifecycle.sql; infrastructure/RELEASE1_DATABASE_BOOTSTRAP_REVIEW.md; docs/architecture/TRANSACTION_LIFECYCLE.md; sql/migrations/004_review_assignment.sql

Current data domains and lifecycle extension



Logical groups and evidence relationships; arrows are not physical foreign keys. The linked baseline ERD has the detailed key sheets.

Supporting detailed diagram: docs/presentation/diagrams/FinTrust_ERD.pdf

28. DynamoDB Role

LOCAL VERIFIED

DynamoDB holds immutable transaction projections for stream-driven delivery and conditional alert claims. It does not replace the PostgreSQL financial ledger or analyst review authority.

SQL projection_outbox coordinates retries when the secondary write fails after commit. The current foundation uses on-demand billing, AWS-owned encryption and no automatic TTL for this delivery state. Mocked tests do not prove live stream processing.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; infrastructure/messaging.py

29. Security / IAM / RBAC

LOCAL VERIFIED

Separate execution roles, scoped actions/resources, account authorization and service-specific database grants limit exposure. IAM rds-db:connect grants connection authority, not SQL table privileges. Database clients require TLS verify-full with the bundled RDS CA.

RDS storage uses AWS-managed aws/rds encryption; the Stage 2 S3 key is not automatically the RDS key. Managed master credentials are for reviewed bootstrap, not application environment variables or browser payloads.

Future 003 rollout must give scoring INSERT/SELECT plus sequence USAGE, API SELECT only, and no UPDATE/DELETE on lifecycle audit. The fixed live runner still supports only its reviewed phases. No broad grants should mask missing permissions.

The earlier multi-user phase changed local backend RBAC. The workbench phase changes presentation only. No AWS policy, credential, resource, deployment or activation changed. Controlled local bearer enrollment is a verification mechanism, not enterprise identity management. Existing scopes and fail-closed financial access remain authoritative.

Source: docs/architecture/TRANSACTION_LIFECYCLE.md; docs/SECURITY.md; infrastructure/iam/DEPLOYER_DESIGN.md

30. POPIA / Data Governance

PLANNED

Names and identity numbers are direct identifiers; accounts and transaction details are linkable personal financial information. Synthetic examples, restricted reads, encryption and sanitized evidence reduce exposure.

This document records design controls, not a legal opinion or certification of POPIA compliance. A data owner must approve purposes, access, retention, disposal and incident procedures before real personal data is processed. No legal retention period is asserted.

Source: docs/data_governance.md; docs/SECURITY.md

31. Retention Strategy

PLANNED

Current processing logs use 14-day retention; queues have finite retention and need investigation before expiration. The current DynamoDB delivery state has no TTL. Retained S3 versions/quarantine and RDS backups/snapshots require explicit disposal authorization.

The design proposes 12 months in the ledger, closed-period full exports in S3 Standard for 3 years and Glacier Flexible Retrieval for 7 years. This is not a legal determination and the export/purge job is not implemented. The archive/ transition after 1,095 days does not apply to monthly/ report summaries.

Older governance files describe different assumptions. Current templates and these stated limits take precedence; never delete ledger rows without reconciliation, checksum/count proof, restore test and approved policy.

Source: docs/OPERATIONS.md; infrastructure/storage.py

32. Cost Governance

LIVE INVENTORY VERIFIED

The project target is USD 10 per month. This is a budget alert target, not a spending cap or proof that the architecture fits within USD 10 before credits. Do not infer free operation from the reported budget spend.

Read-only inventory on 12-13 October 2026 confirms private Single-AZ PostgreSQL 16.15 on db.t4g.micro with 20 GiB gp3 storage, deletion protection and one-day backup retention. RDS compute/storage and retained backups are the main recurring exposure. The active RDS-managed master secret adds Secrets Manager storage/request charges; no secret value was read.

The shared customer-managed S3 KMS key, retained S3 versions/artifacts and log storage also carry recurring or request costs. SQS, DynamoDB, Lambda, SES and transfer add usage-dependent charges. Existing ingest reserved concurrency remains 0; activation is separately gated.

The project VPC has no NAT Gateway or interface endpoint. Only S3/DynamoDB gateway endpoints remain. Historical temporary preflight cleanup is preserved. No new endpoint, proxy, compute resource or billing service was created.

Prices in old stage plans remain dated estimates. Current service rates, remaining credits and a full-month pre-credit bill were not re-quoted in this configuration check. Check them before spending approval; credit-funded usage is not a permanent Free Tier entitlement.

Source: infrastructure/DEPLOYMENT_BOOTSTRAP.md; docs/OPERATIONS.md; docs/EVIDENCE/05-rds/release1-temporary-preflight-cleanup-result.md; docs/EVIDENCE/01-budget/2026-10-12-budget-readonly-inventory.json; docs/EVIDENCE/01-budget/2026-10-13-budget-control-verification.json

33. AWS Budgets

LIVE CONFIGURATION VERIFIED

Preserved the existing FinTrust-Monthly-Budget: COST, USD 10, MONTHLY, healthy, with 50%, 80% and 100% ACTUAL notifications and 100% FORECASTED. All use GREATER_THAN; the actual dollar thresholds are greater than USD 5, 8 and 10. No replacement budget was created.

Preserved My Zero-Spend Budget: MONTHLY with a USD 1 configured limit, but its alert is ACTUAL, ABSOLUTE_VALUE, GREATER_THAN USD 0.01. The alert does not wait for USD 1. Its existing cost types include credits and refunds; a zero reported spend does not mean RDS or KMS stopped charging.

Each of the five alerts has one configured email subscriber, and all use the same existing recipient. Evidence stores only the recipient fingerprint. Subscriber configuration and budget health are verified; recipient activation was not exposed by the contact API and actual email delivery was not tested. Check recipient status or receipt in the console/inbox without generating paid usage.

Both controls cover account 966467878406 across all regions. Application infrastructure remains in af-south-1; the Budgets API is an account-wide service accessed through us-east-1. Project and Environment cost-allocation tags are inactive, so no FinTrust-specific cost filter is claimed. Activation, tag normalization and complete resource attribution remain future reviewed work.

Budgets updates up to three times daily, typically 8-12 hours apart, with billing/notification delays. It warns rather than stopping resources. Read alerts promptly, inspect cost drivers and obtain approval before resource shutdown or cleanup. Monitoring-only budgets/alerts are free; no paid budget reports or automated actions were enabled.

Control	Verified configuration
FinTrust-Monthly-Budget	USD 10/month; 50/80/100% ACTUAL; 100% FORECASTED
My Zero-Spend Budget	ACTUAL > USD 0.01; absolute threshold; USD 1 limit unchanged
Subscribers	One existing email per alert; same recipient; addresses redacted
Scope	Account-wide; Project/Environment cost tags inactive

Source: docs/EVIDENCE/01-budget/2026-10-13-budget-control-verification.json; docs/EVIDENCE/01-budget/2026-10-13-budget-settings-and-recipient-status.json; https://docs.aws.amazon.com/cost-management/latest/userguide/budgets-managing-costs.html; https://docs.aws.amazon.com/cost-management/latest/userguide/budgets-email-recipients.html; https://aws.amazon.com/aws-cost-management/aws-budgets/pricing/

34. Testing Strategy

LOCAL VERIFIED

Historical lifecycle checkpoint 7397f22: 756 passed, 1 skipped, zero failures; focused 62 and PostgreSQL 16 lifecycle 21. The administrator-only skip has separate prior PG16 evidence. Current multi-user verification is recorded below; neither result proves live migration 003/004/005 privileges.

Tests cover identity, threshold boundaries, immutable outcomes, rejected/quarantined rows, correction lineage, partial-write recovery, delivery claims, role/account authorization and browser workflows. Local mocks intentionally avoid AWS. Counts establish tested behavior, not availability, live service permissions or performance.

Multi-user phase: 789 regression passed / 1 administrator-only skip; 27 focused passed; 130 affected checks passed; 48 PostgreSQL 16 passed; browser passed. Focused coverage includes immutable correction lineage, failed/successful/duplicate revalidation, named onboarding and disable/reactivate, role separation, concurrent claims, wrong-owner denial, assignment replay/scope, escalated recovery and browser role/action visibility. Evidence: docs/EVIDENCE/12-e2e/multi-user-operations/.

Risk investigation: 16 new backend tests plus a real loopback browser gate; 65 affected tests; 64 on disposable PostgreSQL 16; full regression 810 passed / 1 expected administrator-only skip. Evidence: docs/EVIDENCE/12-e2e/risk-investigation/. No live AWS transport occurred.

Workbench and documentation phase: 19 focused tests passed, including three loopback browser workflows; 82 affected integration tests passed; full regression 811 passed / 1 expected administrator-only skip. The separate CSV scenario browser gate passed after its legacy review test was updated to claim before deciding. No backend, SQL or AWS changes. Evidence: docs/EVIDENCE/12-e2e/analyst-workbench/.

Local scenario phase at 48399b9: 122 lifecycle/risk/quarantine/RBAC integration and browser tests, two added outcome/role tests and one CSV A/B browser gate passed: 125 selected tests, no failures or skips. Evidence labels individual UI browser versus API checks. No fresh full regression or live AWS E2E is implied. See docs/EVIDENCE/12-e2e/scenario-verification/SCENARIO_RESULTS.md.

Historical V1 gate: 13 October 2026 | Candidate source eb17ed5 includes risk-score display b73866c and the major console overhaul. Final candidate includes a test-isolation correction and a narrow report display/export correction. Full post-correction regression: 847 PASSED | 0 FAILED | 1 SKIPPED (848 collected); six in-suite browser checks passed against isolated PostgreSQL and mocked AWS. A separate four-role CSV/report browser gate also passed. Business rules, APIs and schema are unchanged.

Final gate found and corrected a test-isolation gap: Overview database reads did not use the disposable schema. Four focused failures were resolved by binding db.get_connection in the existing release_db fixture, then the entire suite passed with implicit developer dotenv loading disabled. The sole skip requires a disposable PostgreSQL administrator; prior separate PG16 role proof remains historical.

The separate CSV/report browser gate detected null risk-score fields being added to report rows by the shared presentation renderer. Risk projection is now limited to transaction and risk views. The final browser check verifies exported JSON equals backend rows and CSV values match the report response; no API, scoring or schema behavior changed.

Historical V1 isolated browser proof: recorded /100 scores including zero and missing values; grouped dark navigation; desktop/mobile containment; WHAT HAPPENED, WHY IS IT RISKY and NEXT STEPS; claim, notes and review outcomes; immutable quarantine correction and resulting-transaction navigation; own unknown-account upload recovery; Admin user/status and assignment controls; wrong-Analyst and Auditor read-only restrictions; real filtered Insights. Saved screenshots show alternating rows, clear selection/focus and retained investigation context.

Risk Model V2 and explainable UX VERIFIED: 903 PASSED | 0 FAILED | 1 EXPECTED SKIP (904 collected, +56 checks versus baseline). Final focused model/CSV/browser pass: 75; eight previously affected checks passed after explicit V2 oracle updates. Seven in-suite browser gates plus the separate four-role CSV/report gate passed. Preserved financial/audit data and credentials are unchanged. No historical rescoring, AWS contact, push or Linux run.

Source: docs/EVIDENCE/12-e2e/transaction-lifecycle/verification-summary.json; tests/test_transaction_lifecycle.py

35. CI/CD

LOCAL VERIFIED

GitHub Actions provides exact-source Linux Python 3.12 packaging/import and disposable PostgreSQL 16 gates. Dependency wheels, handlers, native PostgreSQL imports, CA loading, archive contents and checksum are tied to the release manifest.

Build/test workflows do not authorize deployment. A push and current-source CI run require their own scope. Historical green runs and artifacts are preserved; source movement and lifecycle changes require a fresh gate before promotion.

Source: infrastructure/LINUX_CI_GATE.md; .github/workflows

36. Release Verification

PENDING VERIFICATION

Risk Model V2 and explainable UX VERIFIED: 903 PASSED | 0 FAILED | 1 EXPECTED SKIP (904 collected, +56 checks versus baseline). Final focused model/CSV/browser pass: 75; eight previously affected checks passed after explicit V2 oracle updates. Seven in-suite browser gates plus the separate four-role CSV/report gate passed. Preserved financial/audit data and credentials are unchanged. No historical rescoring, AWS contact, push or Linux run.

Final local re-freeze and exact-source Linux Python 3.12/x86_64 verification come next. Live schema chain must include reviewed migration 006 before V2 scoring is enabled. No live step was performed.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; infrastructure/HARDENED_RUNTIME_RELEASE.md

37. Challenges and Failures

LOCAL VERIFIED

Live Stage 3 exposed missing DescribeEngineDefaultParameters and retained named parameter-group cleanup concerns. Stage 5 exposed provider-side tagged log creation authorization requirements that static validation could not prove; one-variable diagnostics narrowed the cause.

The read-only RDS preflight proved private verified TLS connectivity and found missing base schema, preventing an unsafe incremental migration. Quota constraints required a separately approved one-shot activation with finally restoration and revocation.

Local lifecycle verification caught retry/recovery state defects; financial storage and processing failure now remain separate. Historical outputs stay in EVIDENCE, including failures rather than only successes.

Source: infrastructure/STAGE5_PERMANENT_FIX.md; docs/EVIDENCE/05-rds/release1-live-readonly-alternative-preflight-result.md; docs/architecture/TRANSACTION_LIFECYCLE.md

38. Lessons Learned

LOCAL VERIFIED

A valid CloudFormation template does not prove live provider authorization. Simulated IAM context does not guarantee identical runtime context. Change one variable and capture both failure and recovery evidence.

Preflight must confirm the actual database baseline. Retained named resources can collide with fresh CREATE attempts. Disabled concurrency is a deployment safety control, not evidence of runtime correctness.

Financial acceptance, risk, review and notification delivery must remain independent. Never hide gaps with fabricated timestamps, UI-only labels, silent resets or indiscriminate permission broadening.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md

39. Current Deployment State

PENDING VERIFICATION

Historical foundation evidence covers network, S3/KMS, RDS PostgreSQL and DynamoDB/SQS. Read-only live cost inventory on 12-13 October 2026 confirms those stacks and ingest are CREATE_COMPLETE, with ingest reserved concurrency 0. Existing budgets are healthy and preserved; no AWS mutation occurred. Historical deployed artifacts are distinct from current source.

The 11 October 2026 live read-only check used PostgreSQL 16.15 with TLS verify-full and found the application base schema missing. Cleanup then removed temporary runner/network stacks and billable endpoint, preserving the five existing stacks and retained evidence.

Current application source is local verified. Complete cloud integration, current-source Linux packaging and live SQL bootstrap are pending. Do not call the whole application deployed.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/EVIDENCE/05-rds/release1-live-readonly-alternative-preflight-result.md; docs/EVIDENCE/05-rds/release1-temporary-preflight-cleanup-result.md

40. Future Roadmap

PLANNED

Next: exact-source Linux Python 3.12 x86_64 verification, then separately approved deployment/wiring and live AWS E2E. Local 20-scenario evidence is verified at 48399b9; AI remains planned.

After local closure: current Linux artifact gate, separately reviewed base bootstrap and 001/002/003/004/005 privilege/catalog chain, controlled live integration and recovery evidence. HA, federation, accounting extensions, archival automation and production capacity review are later scope.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

41. AI Investigation Assistant

PLANNED

PLANNED / NOT IMPLEMENTED. A future assistant could summarize existing authorized evidence and explain deterministic signals, with sources and human approval. It must not change ledger identity, authorize funds movement or decide confirmed fraud automatically.

No model integration, autonomous investigation, accuracy evaluation or production data transfer exists in the current release. Privacy, access boundaries, audit, quality and cost require a separate approved design.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md

42. Local Workflow Completion and Remaining Cloud Gates

LOCAL VERIFIED | LIVE AWS PENDING

13 October 2026 | Workflow continuity and own-upload correction locally verified: 847 regression passed, 1 expected administrator-only skip, zero failures; final four-role browser passed; three investigation/missing-evidence/own-upload browser checks passed. Implementation: 209700a. AWS untouched; no schema change, credential reset or push.

The reported quarantine 503 came from lost in-memory mock versions after restart, not a valid reason to overwrite immutable evidence. Local synthetic object versions and typed DynamoDB claims now persist in ignored build/local-runtime. Exact pinned originals are checked; absent evidence preserves authorized metadata/history and blocks new writes.

Correction uses assigned-account fields, repeats validation and duplicate detection in the worker, retains original identity/provenance and records human/system events. Own unknown-account recovery is explicitly authorized for the original local uploader only. No schema expansion, risk-rule drift or role inheritance.

The actual local server was restarted with the existing credential and without reset/seeding. All four static assets match source; unauthenticated financial reads are denied; existing financial/audit rows were preserved. Already-lost historical original bytes and missing historical ownership evidence cannot be invented.

Local tests use real isolated PostgreSQL and mocked AWS transports. Exact current-source Linux/Python 3.12 and live RDS bootstrap/deployment/wiring/SES/DLQ/report delivery remain separate gates. Notifications remain session-scoped; a durable inbox/full report catalogue and AI assistant remain future work.

Final navigation/copy polish: 0056a59. Recovered transactions activate Transactions, not Quarantine; LOW entries use Risk Assessment. Three focused browser checks passed; a stalled investigation attempt was rerun alone and passed. Earlier full-suite result remains 847 passed / 1 expected skip; the final polish has targeted browser verification, not a second full-suite claim.

Historical V1 gate: 13 October 2026 | Candidate source eb17ed5 includes risk-score display b73866c and the major console overhaul. Final candidate includes a test-isolation correction and a narrow report display/export correction. Full post-correction regression: 847 PASSED | 0 FAILED | 1 SKIPPED (848 collected); six in-suite browser checks passed against isolated PostgreSQL and mocked AWS. A separate four-role CSV/report browser gate also passed. Business rules, APIs and schema are unchanged.

Historical V1 isolated browser proof: recorded /100 scores including zero and missing values; grouped dark navigation; desktop/mobile containment; WHAT HAPPENED, WHY IS IT RISKY and NEXT STEPS; claim, notes and review outcomes; immutable quarantine correction and resulting-transaction navigation; own unknown-account upload recovery; Admin user/status and assignment controls; wrong-Analyst and Auditor read-only restrictions; real filtered Insights. Saved screenshots show alternating rows, clear selection/focus and retained investigation context.

Historical a474566 baseline: Authenticated preserved-workspace smoke PASSED as analyst01 (Risk/Compliance Analyst), using the existing credential entered privately in the browser. Overview, Transactions, Risk Events, Review Queue, Quarantine correction form, Accounts/Account History, Insights and Reports passed. Recorded scores, 0/100 and Not assessed are distinct; all ten Insights value tables match the API; report JSON matches backend rows. The investigation answers WHAT HAPPENED, WHY IS IT RISKY and NEXT STEPS.

Preserved financial and audit rows, credentials, roles, status and account assignments are unchanged. Normal sign-in metadata updated. No recovered case or owned unknown-account case exists in this Analyst scope; their recovery/authorization proofs remain separately labelled isolated evidence. No correction, claim, review outcome or user change was submitted for the smoke.

Flow / requirement	Current local proof	Boundary / outcome
CSV admission and provenance	Real input/API/SQL four-role browser; A/B and exact A replay	First uploader recorded before worker processing; malformed files create receipts, not ledger rows.
Identity and duplicates	Existing identity, scenario and dataset suites retained	Canonical IDs remain immutable; same/cross-file rows and whole-file replay create no extra ledger entry; conflicts quarantine, similar genuine charges remain accepted.
Validation and scoring	Existing LOW/MEDIUM/HIGH and frozen rule tests pass	All valid risk levels remain in ledger. Velocity remains >5 accepted in the closed 5-minute window; hourly alternative deferred.
Quarantine recovery	Field correction -> outbox -> worker -> accepted link, timeline and actor	Original evidence required. Correction is pending until worker outcome; repeat validation and dedupe.
Own unknown-account rows	Nine authorization checks plus browser accepted-path proof	Original authenticated uploader only; assigned existing target account; no known-unassigned access or duplicate-file ownership transfer.
Risk investigation / review	Claim, note, Clear/Confirm/Escalate and multi-user checks retained	Atomic owner/version conflict; Admin governs access, Auditor reads, Maintainer handles technical recovery; no automated fraud verdict.
Alert and technical failure	Provider-outage, claim/idempotency and retry/outbox checks	Ledger remains available when delivery evidence is unavailable. SENT/ALERTED must be proven; no blind uncertain-send retry.
Batch reconciliation / timeline	Owned mixed-batch detail, per-row recorded timeline and scoped audit	Received = accepted + quarantined + duplicate + failed + pending; every outcome stays visible within authority.
Reports and account history	UTC inclusive-start/exclusive-end period + currency SQL checks; exports	Accepted ledger net movement per currency from zero, not current balance or FX. Export says current page; scheduled cloud delivery pending.
Local runtime continuity	Separate mock sessions restore exact versions and typed DynamoDB; server baseline retained	Ignored SQLite backing for local synthetic mocks only. Historic already-lost bytes are not fabricated.
Usability and evidence	1100/1366/1920 layouts, drawer/form/recovered transaction screenshots	Single Details action, compact queue, human age, backend lifecycle, bounded technical detail, inline errors.

Flow / requirement	Current local proof	Boundary / outcome
Cloud readiness	Local 20-scenario checkpoint remains verified; budgets preserved	Current-source Linux, live bootstrap/wiring/SES/DLQ/reports and live E2E remain approval gates.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/EVIDENCE/12-e2e/workflow-continuity/verification-summary.json; docs/EVIDENCE/12-e2e/workflow-continuity/local-server-restart.json

43. Risk V2 Presentation Evidence

LOCAL VERIFIED

Controlled local presentation example: 150,000 ZAR; 8 accepted transactions in the closed 09:55-10:00 UTC window; country US versus ZA. Amount +25, velocity +25, cross-border +15, duplicate +0 = 65% - HIGH. Transaction -> Measured values -> Components -> Score -> Risk level -> Analyst investigation. This is not a probability of fraud; there is no invented partial velocity weight.

User-facing scores show a percentage, including 0%; missing assessment stays Not assessed. Rule-based risk score. This percentage represents the configured risk score, not the probability of fraud. Numeric API/storage semantics stay 0-100. Historical amount bands are grouped for display and scenario counts, with original identifiers available in technical evidence.

Source: docs/EVIDENCE/12-e2e/risk-model-v2/presentation-example.json

44. If I Had More Time and Budget

PLANNED

PLANNED - BEHAVIOUR-AWARE MONITORING: unusual amount against account baseline; unusual time/after-hours; unfamiliar country/geography or channel; new counterparty; dormant-account reactivation; bursts; rapid movement of funds; repeated payments below thresholds; historical behaviour deviation. None contributes points in Release 1.

A transaction at night is not automatically suspicious. It becomes a stronger signal when it differs from the account's normal behaviour. These features need adequate history, context, validation and governance before use.

CURRENT DESIGN: SQS FIFO buffers work; event-driven Lambda workers use per-account ordering and controlled concurrency; SQL owns the ledger and workflows, DynamoDB projections/delivery claims are independent, and retries/DLQ concern technical failures. The design has no NAT and remains cost-conscious. Local/mock proof is not proof of live wiring or production capacity.

FUTURE PRODUCTION HARDENING: 10k/100k/1M transaction load tests; concurrency/connection tuning; FIFO message-group strategy; high-throughput FIFO only if justified; RDS Proxy; queue-depth alarms; Multi-AZ; source-feed monitoring; configurable SLAs; alert aggregation; DR tests. The architecture is designed for elastic processing, but production-scale performance testing and connection tuning remain a future hardening step.

PLANNED - ADVANCED INTELLIGENCE: streaming ingestion, anomaly detection, AI Investigation Assistant with human review and authorised evidence, richer account/customer context, and governed adaptive thresholds. No AI or ML was added. Future features must improve What happened? Why is it risky? What should I do next?

Source: https://docs.aws.amazon.com/lambda/latest/dg/services-sqs-scaling.html

45. References

LOCAL VERIFIED

Scope authority is the original user-supplied FinTrust brief. Current flow/lifecycle contracts, SQL, frozen rules, templates and evidence establish implementation status. Online sources validate engineering choices without redefining requirements. Historical narrative is subordinate to current evidence.

The document inventory classifies every authored Markdown/text/PDF. Active deployment/tooling contracts remain supporting references. Historical evidence remains unchanged; superseded clean narrative is archived where safe.

Regenerate both PDFs with python tools/build_project_docs.py after editing docs/source/project-master.json and project-progress.json. Rendering dependencies are reportlab and PyMuPDF. Update explanatory material in Master, status/history in Progress, and actual proof in EVIDENCE.

DECISION: Single owner with row lock and version | SOURCE: https://www.postgresql.org/docs/16/explicit-locking.html | WHY IT APPLIES: Concurrent staff must not overwrite ownership | HOW FINTRUST USES IT: SELECT FOR UPDATE plus expected_version and immutable history.

DECISION: Server-side role, ownership and account checks | SOURCE: https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html | WHY IT APPLIES: The brief requires accountable separation of duties | HOW FINTRUST USES IT: Deny unsupported actions and validate owner/account/active role.

DECISION: Controlled local credential enrollment | SOURCE: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html | WHY IT APPLIES: Named sign-in must not expose credentials or imply production federation | HOW FINTRUST USES IT: Private prompt, unique opaque credentials, hashes only, disable checks.

DECISION: Actor and outcome audit without secrets | SOURCE: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html | WHY IT APPLIES: Investigations require attributable history | HOW FINTRUST USES IT: Reuse append-only SQL history and versioned governance receipts; no credential logging.

DECISION: list-preserving investigation drawer, compact filters and visible triage | SOURCE: https://docs.datadoghq.com/security/cloud_siem/triage_and_investigate/investigate_security_signals/ | WHY IT APPLIES: Analysts need evidence and next steps without losing queue context | HOW FINTRUST USES IT: Adapt interaction principles to transaction risk, with original branding and backend-enforced ownership; no copied icons, wording or pixel layout.

DECISION: Reuse scoped aggregate and queue reads | SOURCE: backend/fintrust/frontend_workflows.py; visual_insights.py; workflow_api.py | WHY IT APPLIES: The brief requires evidence-backed triage without fabricated totals | HOW FINTRUST USES IT: Independent loading/error states, explicit count bounds and unconfigured SLA handling; no new risk or database model.

DECISION: Preserve existing monthly and zero-spend budget controls | SOURCE: AWS Budgets managing-costs and email-recipient guidance | WHY IT APPLIES: Avoid duplicate alerts while proving actual threshold/scope configuration | HOW FINTRUST USES IT: Account-wide read-only verification,

masked configured subscriber evidence, periodic-notification limitations and separate live deployment approval.

Current UX proof: docs/EVIDENCE/12-e2e/analyst-ux-correction/verification-summary.json, isolated PostgreSQL regression results and authenticated browser screenshots. No AWS mutation, Linux gate, schema change or credential reset occurred in this phase. Historical restart instruction superseded: current port-5001 server has been restarted and verified against the workflow-continuity evidence. Live AWS E2E remains pending.

DECISION: Keep native tables and keyboard-operable action buttons | SOURCE: https://www.w3.org/WAI/ARIA/apg/patterns/table/ | WHY IT APPLIES: Analysts need dense lists without inaccessible custom grids | HOW FINTRUST USES IT: Native headings/cells, button entry, visible focus and drawer focus restoration.

DECISION: Aggregate authorized filtered rows before bounding the detail list | SOURCE: https://www.postgresql.org/docs/16/sql-select.html | WHY IT APPLIES: Analytical counts must not depend on the displayed page | HOW FINTRUST USES IT: Parameterized WHERE scope before GROUP BY; deterministic date/identity ordering for the latest 25 accepted entries.

DECISION: Conditional immutable first-upload authority | SOURCE: https://docs.aws.amazon.com/AmazonS3/latest/userguide/conditional-writes.html | WHY IT APPLIES: Duplicate or concurrent uploads must not transfer ownership | HOW FINTRUST USES IT: Trusted local first-admission receipt, conditional create, versioned source pointer; known accounts still require assignment.

DECISION: Keep missing original evidence visible and fail closed for new writes | SOURCE: https://docs.aws.amazon.com/AmazonS3/latest/userguide/RetrievingObjectVersions.html | WHY IT APPLIES: Financial correction needs the recorded original | HOW FINTRUST USES IT: Pinned-version reads and explicit evidence health; no latest-version substitution.

DECISION: Separate read authority from financial correction | SOURCE: https://community.owasp.org/Access_Control | WHY IT APPLIES: Governance is not Analyst authority | HOW FINTRUST USES IT: Existing role checks plus authenticated original ownership and real assigned target; Admin oversight remains read-only.

The prior a474566 freeze is retained as historical baseline evidence. Current V2 source requires final local re-freeze before exact-source Linux and controlled live wiring. See docs/EVIDENCE/12-e2e/risk-model-v2/verification-summary.json.

DECISION: Reuse frozen JSON for component measurements | SOURCE: https://www.postgresql.org/docs/16/datatype-json.html | WHY IT APPLIES: existing processed_transactions.result is authoritative structured evidence | HOW FINTRUST USES IT: add component fields to new results; no backfill or competing score table.

DECISION: Preserve timestamp, version and attribution | SOURCE: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html | WHY IT APPLIES: reconstructing an investigation requires context and recorded outcomes | HOW FINTRUST USES IT: frozen evaluation evidence and existing append-only human/system audit.

DECISION: Store exact timing proximity as decimal text | SOURCE: https://boto3.amazonaws.com/v1/documentation/api/latest/_modules/boto3/dynamodb/types.html | WHY IT APPLIES: Boto3 DynamoDB rejects float values | HOW FINTRUST USES IT: one JSON-compatible

frozen measurement reused by SQL/API/projection.

DECISION: Keep capacity tuning planned | SOURCE: https://docs.aws.amazon.com/lambda/latest/dg/services-sqs-scaling.html | WHY IT APPLIES: FIFO groups and configured concurrency bound consumers | HOW FINTRUST USES IT: preserve current design; require real load/connection testing before claiming capacity.

Source: docs/architecture/FINTRUST_FLOW_AUDIT.md; docs/architecture/TRANSACTION_LIFECYCLE.md; docs/source/documentation-inventory.json; https://www.postgresql.org/docs/16/explicit-locking.html; https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html; https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html; https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html; https://docs.datadoghq.com/security/cloud_siem/triage_and_investigate/investigate_security_signals/; sql/migrations/005_investigation_notes.sql; backend/fintrust/investigation.py; docs/EVIDENCE/12-e2e/risk-investigation/verification-summary.json; docs/EVIDENCE/12-e2e/analyst-workbench/verification-summary.json; https://docs.aws.amazon.com/cost-management/latest/userguide/budgets-managing-costs.html; https://docs.aws.amazon.com/cost-management/latest/userguide/budgets-email-recipients.html; docs/EVIDENCE/12-e2e/console-overhaul/final-local-freeze.json